Антифрод-контур мониторинга транзакций для мобильного платёжного приложения

Предложение на технологическую задачу Astana Hub · Заказчик: Monexsol Ltd. · Исполнитель: Ибрагимов Санжар Жаксылыкович (физическое лицо) · ноябрь 2026

> **Что предлагаю.** Разработку антифрод-контура под заказчика на основе готового работающего PoC. Контур разворачивается в инфраструктуре Monexsol в каждой стране присутствия, а исходный код передаётся заказчику. PoC уже закрывает пункты 1–7 раздела 5 ТЗ и все шесть сценариев раздела 4: оценка до проведения, правила и ML, устройство и сессия, дропперы и мультиаккаунты, разбор инцидентов, объяснимость, холодный старт.
> **Сроки:** PoC в тестовой среде заказчика — 2 недели после доступа к ней; подготовка к пилоту — 8 недель; пилот — от 2 месяцев.
> **Стоимость:** PoC — бесплатно. Подготовка к пилоту и сопровождение — по договорённости после PoC, оценка трудозатрат приведена в разделе 7.
> **Прототип:** `https://github.com/SanzharIbragimov/fraud-monitor`

1. Решение и архитектура

Это разработка под заказчика, а не коробочный продукт. Сервис на Python (FastAPI) стоит в синхронной цепочке платежа: бэкенд приложения отправляет событие (платёж, вход, привязку карты, смену данных, получение бонуса) и получает решение с причинами.

Порядок обработки события: проверка страны и валюты → поведенческие признаки (профиль суммы, известные получатели и устройства, скользящие окна частоты, граф «отправитель → получатель») → стоп-листы страны → правила аналитика → ML-вероятность (с бюджетом времени) → итоговый балл и действие по порогам страны → инцидент для разбора → вебхук.

- **Правила** — декларативные условия над 36 признаками; ссылки на лимиты страны (`$limits.large_transfer`). Аналитик правит их в панели: изменение проверяется, получает версию, пишется в журнал и применяется без перезапуска.
- **ML** — логистическая регрессия на 29 поведенческих признаках. Вклад каждого признака виден в причинах. На старте модель обучена на синтетических типологиях, затем дообучается на решениях аналитиков. При накоплении данных её можно заменить на градиентный бустинг, контракт API при этом не меняется.
- **Хранилища:** в прототипе — память процесса и SQLite. Для пилота: Redis для скользящих окон и профилей (несколько экземпляров), PostgreSQL для инцидентов, журнала и списков.
- **Рабочее место аналитика:** мониторинг, очередь инцидентов, редактор правил, стоп-листы, вебхуки, журнал.

2. Матрица соответствия

Сценарии раздела 4 (проверено на вымышленных данных)

Сценарий	Статус	Сигналы	Выявлено операций	Выявлено инцидентов
Социальная инженерия	выполняется	звонок во время перевода, удалённый доступ, первый перевод новому получателю, сумма в 4+ раза выше обычной, серия новых получателей	90,0%	91,9%
Захват учётной записи	выполняется	новое устройство, эмулятор, root, подбор пароля, смена пароля или телефона перед переводом, IP другой страны, невозможное перемещение	94,0%	100,0%
Скомпрометированные карты	выполняется	3+ карты на устройстве за сутки, карта у нескольких аккаунтов, серия пробных мелких платежей	88,1%	100,0%

Дропперские схемы	выполняется	у получателя 4+ отправителя за сутки, вывод 80%+ входящих за 2 ч новому получателю	83,3%	83,3%
Мультиаккаунты	выполняется	несколько аккаунтов на устройстве, бонус с одного устройства для 2+ аккаунтов	91,5%	100,0%
Получатель в стоп-листе	выполняется	совпадение получателя, устройства, карты или клиента с национальным или внутренним списком страны	100,0%	100,0%

Функциональные требования раздела 5

Требование	Статус	Как сделано в прототипе
1. Оценка до проведения: пропустить / подтверждение / отклонить	выполняется	`POST /v1/score` → allow / challenge / decline, балл 0–100, сценарии, причины
2. Правила + ML; правила меняет аналитик без разработчиков	выполняется	декларативные правила (лимиты, частота, суммы, время, гео) в YAML; редактор в панели и API с проверкой, версией, журналом и применением без перезапуска; ML добавляет до 40 баллов
3. Устройство и сессия, защита от захвата аккаунта	частично	сигналы устройства и сессии обрабатываются (смена устройства, эмулятор, root, аномалии входа, гео). Мобильный SDK не разработан: подготовлен контракт данных для iOS и Android
4. Дропперы, транзитные счета, мультиаккаунты	выполняется	граф «отправитель → получатель» в скользящих окнах: много отправителей, быстрый вывод входящих, аккаунты и бонусы на одном устройстве
5. Разбор инцидентов: очередь, рабочее место, журнал	выполняется	очередь по баллу, карточка с причинами и признаками, решение «мошенничество / легитимно», добавление в стоп-лист, журнал действий
6. Объяснимость по каждой операции	выполняется	в каждом ответе: код причины, источник (правило / ML / список), баллы, текст; для ML — главные факторы
7. Холодный старт без исторических данных	выполняется	стартовые правила и модель, обученная на синтетических типологиях; дообучение на решениях аналитиков заказчика
8. Национальные и внутренние стоп-листы	частично	импорт CSV через API, панель и папку с автообновлением; раздельно по странам. Подключение к конкретным национальным системам — после получения формата обмена
9. Несколько юрисдикций и валют	выполняется	у каждой страны свои валюта, пороги, лимиты, списки и резервная политика; правила могут ссылаться на лимиты страны

Интеграция, данные и безопасность (раздел 7)

Требование	Статус	Комментарий
REST API, вебхуки, OpenAPI, тестовая среда	выполняется	OpenAPI 3 (/docs); вебхуки с подписью HMAC-SHA256 и повторами; тестовая среда — тот же Docker-образ
SDK для сбора признаков устройства (iOS, Android)	не выполняется	только контракт данных (docs/device-signals.md); реализация — на этапе подготовки пилота
Импорт списков с автообновлением	выполняется	API и папка обмена с опросом изменений
Минимум данных, токены вместо карт, псевдонимизация	выполняется	PAN не принимается; BIN, последние 4 цифры, токен; HMAC-хеши идентификаторов на стороне заказчика
Шифрование, роли, журнал	частично	роли по API-ключам и журнал действий и изменений правил есть; TLS и шифрование хранилища — на уровне инфраструктуры
PCI DSS, ISO/IEC 27001	не выполняется	сертификаций нет
Отчёты для внутреннего контроля и регуляторов	выполняется	выгрузки CSV по инцидентам и срабатываниям правил

Опционально: санкционные списки и ПДЛ	не выполняется	в предложение не входит

3. Показатели раздела 6

Показатель	Статус	Результат на стенде
Время решения ≤ 200 мс (95%), ≤ 500 мс (99%)	выполняется	100 событий/с: p95 4,8 мс, p99 9,4 мс; 250 событий/с: p95 7,0 мс. Движок — 0,14 мс на событие
100 событий/с с ростом до 500	частично	100 и 250 — подтверждено на одном процессе (2 vCPU). 500 на одном процессе: p95 410 мс — не укладывается; нужны несколько экземпляров и общее состояние в Redis (этап подготовки пилота)
Доступность 99,9%	частично	в прототипе: health-check, резервная политика, бюджет времени на ML. Сама доступность зависит от инфраструктуры (2+ экземпляра, мониторинг) и не измерялась
Поведение при сбое	выполняется	клиент с таймаутом: до лимита суммы — пропуск, выше — отказ или отложенная проверка; лимиты по странам задаёт заказчик
Размещение и локализация данных	выполняется	Docker-образ, разворачивается в облаке или ЦОД заказчика в каждой стране отдельно; данные не покидают страну

Качество на вымышленном потоке (83 614 событий, 14 дней; модель обучена на другом потоке): выявлено 90,3% мошеннических операций при 0,35% ложных срабатываний (подтверждение или отказ) и 0,05% ложных отказов; на ручной разбор ушло 0,10% легитимных операций. Только на правилах: 69,5% / 0,10%.

> Все данные вымышленные. Синтетический фрод отделить от честных операций проще, чем реальный, поэтому эти цифры показывают, что логика работает, а не прогнозируют показатели пилота. Стенд нагрузки: один процесс, 2 vCPU, клиент нагрузки на той же машине.

4. Размещение и локализация персональных данных

- Отдельный экземпляр в каждой стране: в облаке или ЦОД, который соответствует требованиям о локализации. Данные одной страны в другую не передаются; правила и модель распространяются как конфигурация.
- Заказчик передаёт минимум: псевдонимизированные ID (HMAC с секретом заказчика), токен карты, BIN и последние 4 цифры. Полные номера карт не принимаются.
- Если код разворачивается у заказчика, исполнитель к персональным данным доступа не получает. Доступ для разбора и дообучения — только по соглашению об обработке данных и NDA.

5. Опыт

Внедрений антифрод-систем в банках и финтех-компаниях у меня нет — указываю это прямо. Релевантный опыт:

- Системный аналитик государственных информационных систем с 2024 г.: требования, ТЗ, BPMN, интеграции, демо заказчикам, обучение сотрудников.
- Data Engineer, 2023–2024: Python, SQL, загрузка и обработка данных.
- Магистрант «Информационные системы», Университет «Туран-Астана».
- Прототипы на GitHub (SanzharIbragimov): fraud-monitor (этот PoC), payment-antifraud (антифрод онлайн-оплаты и чарджбэки), tender-monitor, fuel-report.

6. Условия PoC

Параметр	Условие
Стоимость	Бесплатно

Срок	2 недели после доступа к тестовой среде. Неделя 1: развёртывание, интеграция с тестовым бэкендом и вебхуками, тестовые сценарии раздела 4 совместно с заказчиком. Неделя 2: прогон сценариев, нагрузочный тест 100 событий/с, отчёт с объяснением по каждой операции
Данные	Исторические данные не нужны. Нужны: формат событий тестового бэкенда, тестовые сценарии, перечень стран первой очереди и их лимиты
Критерии приёмки	Четыре условия раздела 8 ТЗ: шесть сценариев, p95 ≤ 200 мс при 100 событиях/с, вызов оценки и вебхуки в тестовой среде, причина по каждой операции

7. Модель и стоимость коммерческого использования

Модель — **совместная разработка с передачей исходного кода**: система работает в инфраструктуре Monexsol без подписки и платы за объём операций. Работы после PoC оцениваются по трудозатратам; сумма фиксируется договором после PoC.

Этап	Срок	Состав
Подготовка к пилоту	8 недель	Redis и PostgreSQL, несколько экземпляров (500 событий/с), подключение списков национальных систем, калибровка на тестовом трафике, теневой режим, документация, обучение аналитиков
Пилот	от 2 месяцев	Ограниченный поток реальных операций, еженедельная калибровка правил, дообучение модели, отчёт по трём показателям пилота
Сопровождение	помесячно	Доработки правил и модели, исправление ошибок, консультации аналитиков

8. Сроки и трудозатраты интеграции со стороны заказчика

Работа	Оценка
Бэкенд: вызов `/v1/score` перед проведением операции и обработка ответа, резервная политика (есть готовый клиент)	3–5 дней
Мобильное приложение: сигналы устройства по контракту (iOS и Android, стандартные API ОС)	1–2 недели на платформу
Приём вебхуков и проверка подписи	1–2 дня
Выгрузка стоп-листов в папку обмена или API	1 день
DevOps: развёртывание Docker, Redis, PostgreSQL, TLS, мониторинг в каждой стране	3–5 дней на страну

Что нужно от заказчика

- Доступ к тестовой среде и формат событий; перечень стран первой очереди, валюты и лимиты.
- Тестовые сценарии раздела 4 (готовы подготовить совместно); формат обмена списками от национальных систем.
- Аналитик для разбора инцидентов в пилоте; NDA и соглашение об обработке данных до пилота.

Риски

Риск	Как снижаю
Исполнитель — один человек, нет круглосуточной поддержки с реакцией 30 минут	Система работает у заказчика, первую линию и инфраструктуру ведёт DevOps заказчика; при сбое срабатывает резервная политика. Режим поддержки исполнителя фиксируется договором
Нет внедрений в финсекторе	Бесплатный PoC на условиях раздела 8 позволяет проверить решение до любых обязательств
Пороги и модель настроены на синтетике	Теневой режим перед пилотом, еженедельная калибровка, дообучение на решениях аналитиков
500 событий/с не подтверждено	Перенос состояния в Redis и горизонтальное масштабирование — первая задача подготовки к пилоту, с повторным нагрузочным тестом
Нет PCI DSS и ISO 27001	Полные номера карт не обрабатываются; размещение в сертифицированной инфраструктуре заказчика

Исполнитель

Ибрагимов Санжар Жаксылыкович, физическое лицо · sanzhar.ibragimov3@gmail.com · +7 707 777 18 88 · GitHub: SanzharIbragimov